Snapshot-Guided Selection: Knowledge-Graph Attribution of Threat Reports with a Small Open Model

Shinhyuk Park
Department of Computer Science, Angelo State University, San Angelo, TX, USA
spark43@angelo.edu
CS 6338 Knowledge Engineering, Final Project

***Abstract*—Small open-weight language models lag far behind frontier models at cyber-threat-intelligence (CTI) entity attribution: reading a threat-report passage and naming the MITRE ATT&CK technique or CWE weakness it describes. On the CTIConnect benchmark, Llama-3-8B reaches 0.28 F1 on ATT&CK attribution (ATA) and 0.40 on CWE attribution (VCA), against 0.90 and 0.76 for GPT-5. We present Snapshot-Guided Selection (SGS), a GraphRAG system in which a Neo4j property graph, built only from the benchmark's own knowledge-base snapshot (ATT&CK, CWE, CAPEC, CVE) plus an LLM-extracted, span-grounded report layer, supplies candidates and evidence, and a local Llama-3-8B-Instruct only chooses one of five listed identifiers under constrained decoding. Every edge carries provenance and a confidence; LLM-extracted edges get theirs from a stratified audit (estimated precision 0.61). Neo4j Graph Data Science (PageRank, Louvain, betweenness, shortest paths) characterizes the graph and yields retrieval priors, and every answer carries graph citations that can be checked in Cypher. On a 73-question development split, SGS raises F1 from 0.26 for vanilla RAG to 0.47 (paired bootstrap +0.21, 95% CI [0.08, 0.34]; McNemar $p = 0.0005$), removes fabricated and hedged identifiers (closed-book fabricates in 10% of answers, vanilla RAG hedges in 23%), and all 249 cited paths verify against the graph. Because the split was also used for development, these figures are optimistic.**

***Index Terms*—knowledge graphs, GraphRAG, cyber threat intelligence, MITRE ATT&CK, CWE, graph data science, small language models**

I. Introduction

Security operations and threat-intelligence teams read vendor reports and map what attackers did to shared taxonomies: MITRE ATT&CK techniques for detection engineering and coverage analysis, and CWE weaknesses for vulnerability management. CTIConnect [1] turns this into a benchmark. Its entity-attribution tasks give a short passage from a report and ask for the single ATT&CK technique (ATA, 160 questions) or CWE (VCA, 219 questions) behind it. The benchmark authors find that attribution is the one task family limited by model reasoning rather than retrieval: entity-linking tasks reach about 0.97 F1 with domain retrieval, while Llama-3-8B scores 0.28 (ATA) and 0.40 (VCA) against GPT-5's 0.90 and 0.76.

The gap matters in practice. Threat reports and the internal incidents they are compared with are often sensitive, so an analyst may need a model that runs locally; frontier models are not an option. This project asks whether a knowledge graph built from the benchmark's own public snapshot, used as a reasoning scaffold rather than a document store, can close part of that gap for a small local model. With the instructor's approval, the scope was narrowed from the original four-task, multi-hop proposal to entity attribution only, the task family where a graph has the most to add, and the system uses only the CTIConnect snapshot so results stay comparable with the paper.

Contributions.

- A snapshot-only CTI property graph (10,289 nodes, 14,438 relationships) in Neo4j, with provenance, timestamps and a confidence on every relationship (Section III).
- A schema-enforced LLM extraction layer that grounds 3,512 attacker behaviors in report text, validated by Pydantic and scored by a tiered confidence audit (Section IV).
- A Graph Data Science analysis of the graph (topology, communities, centrality, paths) and a test of GDS outputs and graph embeddings as retrieval signals (Section V).
- SGS, which hands a small model five graph-built evidence cards and lets it make one constrained choice, and returns Cypher-verifiable citations with each answer, served through a FastAPI service and a Streamlit chatbot (Section VI).
- An evaluation of accuracy with significance tests, identifier hallucination, faithfulness, latency and extraction quality (Section VII).

Code, data pointers, run outputs and setup files are public at https://github.com/shinPark43/CTI-GraphRAG.

II. Related Work

CTI benchmarks and scaffolds. CTIConnect [1] provides 691 questions over heterogeneous CTI sources with closed-book, vanilla-RAG and decompose-then-retrieve (DtR) baselines; we use its attribution questions, its knowledge-base snapshot and its official scorer unchanged. CTIFoundry [2] builds an agent-native scaffold over the same sources: an ontology graph parsed from the knowledge bases and a span-grounded report layer extracted by an LLM. Our build follows its rule that structure the sources already record is parsed with no model, and that prose is handled by an LLM bracketed by

TABLE I
NODE LABELS

Label (key)	Nodes	Content
AttackTechnique (T1059.001)	1,076	title, tactics, platforms, detection advice
Tactic (name)	19	from kill_chain_phases
CWE (CWE-79)	1,342	title, consequences, mitigations (412 empty)
CAPEC (CAPEC-66)	615	name, attack-language description
CVE (CVE-2021-...)	2,751	description; labelled CWE examples
ThreatReport (BLOG-10)	321	title, URL, publication date
ReportChunk (BLOG-10#0)	650	text with character offsets
ReportBehavior	3,512	verbatim attacker-behavior phrase
Source	3	provenance records (Sec. III-B)

TABLE II
RELATIONSHIP TYPES (ALL DIRECTED)

Type	Edges	Method	Derived from
SUBTECHNIQUE_OF	518	derived	ID pattern
REPLACED_BY	103	derived	retired-ID rule R2
IN_TACTIC	1,374	asserted	kill-chain phases
EXPLOITS_WEAKNESS	1,212	asserted	CAPEC → CWE
MAPS_TO_TECHNIQUE	271	asserted	CAPEC → ATT&CK
HAS_WEAKNESS	3,286	asserted	NVD weaknesses
HAS_CHUNK	650	segmented	chunking
HAS_BEHAVIOR	3,512	segmented	verbatim span
GROUNDS	3,512	extracted	LLM, validated

deterministic checks; we reuse its chunking scheme and TTP-extraction prompt. Boyer et al. [3] integrate ontologies and open data into a unified cybersecurity knowledge graph; we take a narrower, task-driven view of the same sources.

Retrieval augmentation over graphs. Retrieval-augmented generation [4] grounds generation in retrieved text, and GraphRAG [5] retrieves over an LLM-built entity graph and its communities. SGS differs in two ways: the graph comes from curated taxonomies rather than from the LLM, and the model is not asked to generate an answer, only to choose among identifiers the graph supplies, which removes identifier hallucination by construction. We fuse rankings with reciprocal-rank fusion [6] and evaluate faithfulness with RAGAS [7].

III. Knowledge-Graph Schema and Ontology Design

The graph is a labelled property graph in Neo4j 5.26 built only from CTIConnect's `corpus_kb` snapshot (pinned commit `554797d`, snapshot date 2025-09-01) and its 321 report summaries. Fig. 1 shows where it sits in the system and Fig. 2 its schema.

A. Node labels and relationship types

Table I lists the node labels. Identifiers are the canonical keys of each source taxonomy, enforced by uniqueness constraints, so every answer the system can give is a node the loader wrote from an official record. Table II lists the relationship types with their derivation; the counts match the Python derivation of the same snapshot and CTIFoundry's counts for it (CTIFoundry reports 1,214 and 272 CAPEC links because three CAPEC records list a link twice).

B. Edge properties: provenance, timestamps, confidence

Every relationship records where it came from and how much to trust it:

- `source`: the id of a `Source` node, which holds the snapshot's repository, pinned commit and date, or the report-layer build (model, prompt, extraction date, counts).
- `method`: *asserted* (stated in a source record), *derived* (a deterministic rule), *segmented* (report chunking) or *extracted* (the LLM), with a free-text `derivation`.
- `loaded_at` (load timestamp) and `confidence`: 1.0 for asserted, derived and segmented edges; for extracted edges, the audited precision of the edge's confidence tier (Section IV-C).

Some types carry more. `HAS_WEAKNESS` keeps NVD's weakness type (1,882 Primary, 1,404 Secondary). `MAPS_TO_TECHNIQUE` keeps CAPEC's own name for the mapped technique and its agreement with the current ATT&CK title, which flags stale mappings (one of 271: CAPEC-662 "Man in the Browser" now points to T1185 "Browser Session Hijacking"). `GROUNDS` keeps the model, prompt, extraction date, the validation checks passed, the soft signals behind its confidence and its tier, and `HAS_BEHAVIOR` keeps the behavior's character span in its report; all 3,512 spans resolve to the exact report text. Indexes cover identifier uniqueness, normalized titles, a relationship index on `GROUNDS.confidence`, and five 3,072-dimensional cosine vector indexes over technique, CWE, CAPEC, CVE and behavior embeddings (text-embedding-3-large).

C. Reference ontologies and the RDF/OWL versus LPG decision

Labels follow the source vocabularies one to one: ATT&CK techniques, sub-techniques and tactics [8], CWE, CAPEC and CVE, keyed by their official identifiers. In STIX 2.1, ATT&CK techniques and CAPEC patterns are both represented as *attack-pattern* objects (ATT&CK is distributed that way) and CVEs as *vulnerability* objects; we keep separate labels because their identifier spaces and their roles in the two tasks differ (a technique or CWE is an answer, a CAPEC or CVE is evidence).

We chose a labelled property graph over RDF/OWL [9] for three reasons. First, the properties that matter here (confidence, character spans, provenance) belong to edges, which a property graph stores directly and RDF needs reification or RDF-star for. Second, the workload is traversal, vector search and graph algorithms, all native to Neo4j and its GDS library. Third, the inference needed is small and deterministic (sub-technique hierarchy, retired identifiers, domain), computed

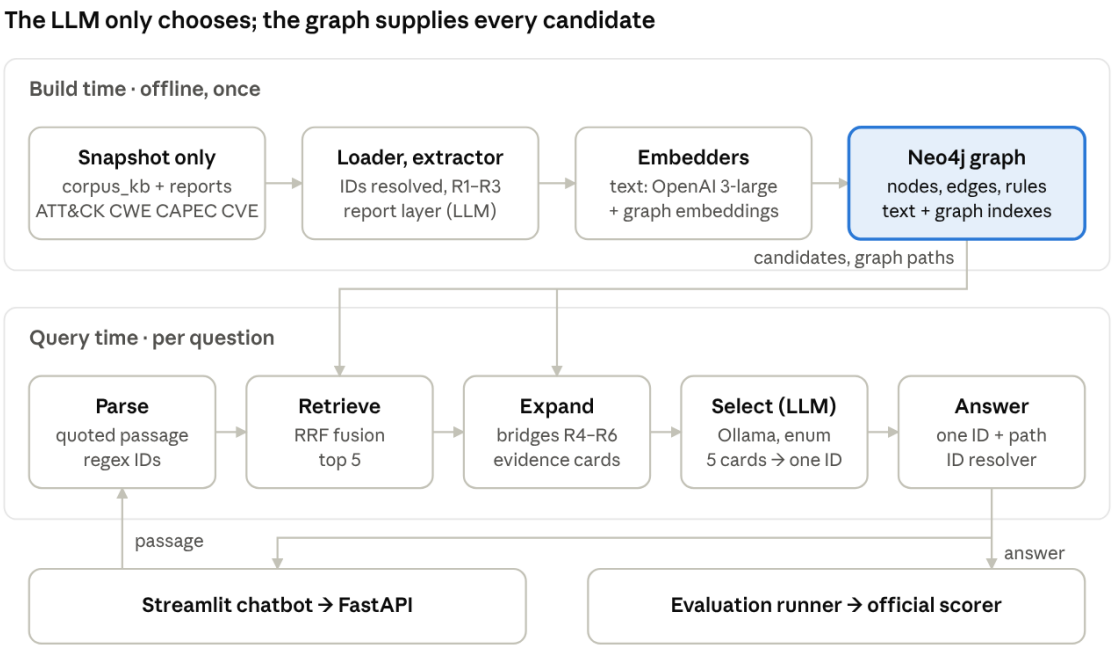


Fig. 1. System architecture. Build time turns the CTIConnect snapshot into a validated Neo4j graph (rules R1–R3, the LLM report layer, text embeddings; GDS scores and provenance are written onto it). At query time the graph supplies five candidates and their evidence cards, Llama-3-8B chooses one under an enum constraint, and the answer returns with its graph paths.

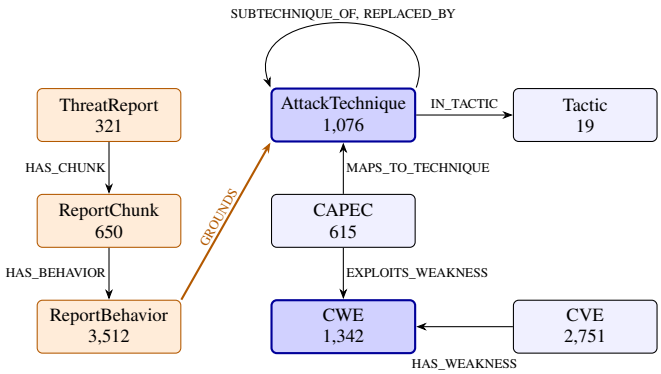


Fig. 2. Graph schema with node counts. Dark blue: answer targets; orange: the LLM report layer.

once at load time as rules R1–R3; no OWL reasoning is required, so the n10s RDF plugin is not used. The cost is weaker interoperability with semantic-web tooling. Within the approved scope we did not build an RDF export.

D. What is excluded, and why

To stay comparable with CTIConnect, the graph uses no outside data (no MITRE STIX bundles, CWE XML or NVD lookups: a cited CVE's NVD entry, for example, names the answer) and none of the benchmark's `construction/` files, whose seeds generated the questions. One consequence is that the graph has no CWE parent–child hierarchy; Section V measures what that costs. Attributes that would narrow the answer space (ATT&CK domain, retired status) are shown on evidence cards but never used as filters: on the development split such filters raised recall only by assuming what the answers look like.

IV. Extraction and Ingestion Architecture

A. Structured ingestion and normalization

A Python loader reads the four snapshot files (fetched at the pinned commit with checksum verification) and writes nodes and edges with batched `UNWIND ... MERGE` statements through the Neo4j driver. Normalization covers identifier formats (CWE identifiers upper-cased; CAPEC's ATT&CK taxonomy entries prefixed with `T`; CVE weakness values kept only if the CWE exists), duplicate links (three CAPEC records list a link twice and are counted once), titles (a normalized lowercase key for lookup) and three snapshot-derived rules: R1 assigns each technique a domain (Enterprise, Mobile, ICS) from its platforms and identifier prefix; R2 finds 103 retired Enterprise parent-level identifiers whose title equals a sub-technique's and links them with `REPLACED_BY`; R3 derives the hierarchy from the identifier pattern and tactics from kill-chain phases. The loader checks every edge count against the in-memory derivation, then embeds one text view per searchable node (title plus record content for techniques and CWEs, name plus description for CAPEC, description for CVE, the phrase for behaviors), cached on disk. A full load takes about 30 seconds.

B. Unstructured extraction: the report layer

Following CTIFoundry [2], each of the 321 report summaries is split at clause boundaries into chunks of 200–900 characters with exact offsets (650 chunks). Each chunk is sent once to the extractor with CTIFoundry's TTP-grounding prompt, its tactic list filled from the snapshot:

```
Extract MITRE ATT&CK techniques from this CTI
report chunk. [...] List every ATTACKER behavior
in the chunk that corresponds to a real ATT&CK
technique. For each: "behavior" = the verbatim
phrase; "technique_id" = the ATT&CK id, most
specific you are confident in; "technique_name" =
official name. STRICT rules: Attacker techniques
ONLY. EXCLUDE defenses/mitigations [...] Do NOT
invent ids.
```

Schema enforcement. Decoding is constrained to a strict JSON schema generated from the Pydantic model `ExtractionReply`: a list of records with required `behavior`, `technique_id` (pattern `^T\d{4}(\.\d{3})?$`) and `technique_name`, and no additional properties. Each returned record is then validated twice by Pydantic: `ExtractedTTP` checks shape and identifier format, and `GroundedBehavior`, validated with the chunk as context, rejects identifiers absent from the snapshot and phrases that do not occur verbatim in the chunk (zero fabrication by construction). The committed layer was extracted with gpt-5.4-mini at the provider's default temperature, before constrained decoding was added; re-validating its 3,741 cached records with the Pydantic path reproduces it byte for byte: 0 schema failures, 6 unknown identifiers and 223 non-verbatim phrases dropped, 3,512 kept, covering 353 techniques and 627 of 650 chunks.

The layer never answers a question from its own source: 0 of 73 development passages occur verbatim in their report's summary, and SGS always excludes the question's own report. It serves as labelled examples of how reports word each technique.

C. Confidence tiers and their audit

The hard checks keep only grounded records but cannot tell a right identifier from a wrong one. Two soft signals sort the 3,512 `GROUNDS` edges into tiers: the agreement (difflib ratio) between the technique name the model wrote and the official title of the identifier it gave, which catches wrong identifiers, and the rank of the technique among all 1,076 for the behavior phrase alone by embedding similarity, which catches context-dependent mappings. We drew a stratified sample of 25 edges per tier (seed 6338) and labelled each correct if the identifier is a right ATT&CK mapping for the behavior in its chunk. The tier's precision becomes the confidence of every edge in it (Table III).

The estimated precision of the layer is 0.61. Errors are mostly sibling sub-techniques (HTML smuggling mapped to `T1027.016` instead of `T1027.006`; Java mapped to `T1059.006`, Python), vague phrases mapped to a technique ("initial access" to `T1190`), and defender actions read as attacker behavior. Name disagreement is not always an error: some reflect ATT&CK renames (`T1574.001` is now "DLL"; extortion falls under `T1657`).

TABLE III
REPORT-LAYER CONFIDENCE TIERS AND AUDITED PRECISION

Tier	Rule	Edges	Precision [95% CI]
supported	agreement ≥ 0.6, rank ≤ 50	2,488	0.76 [0.57, 0.89]
context	agreement ≥ 0.6, rank > 50	934	0.24 [0.12, 0.43]
conflict	agreement < 0.6	90	0.32 [0.17, 0.52]
all	tier-weighted	3,512	0.61

```
CALL gds.graph.project('kb',
  ['AttackTechnique','Tactic','CWE','CAPEC','CVE'],
  {SUBTECHNIQUE_OF: {orientation:'UNDIRECTED'},
   IN_TACTIC: {orientation:'UNDIRECTED'}, ...});
CALL gds.louvain.write('kb',
  {writeProperty:'community', concurrency:1})
YIELD communityCount, modularity;
CALL gds.pageRank.write('kb_directed',
  {writeProperty:'pagerank', dampingFactor:0.85});

// R4, the CAPEC bridge, for a passage vector $v
MATCH (c:CAPEC)
WITH c, vector.similarity.cosine(c.embedding, $v) AS s
ORDER BY s DESC LIMIT 10
MATCH (c)-[:EXPLOITS_WEAKNESS]->(w:CWE)
RETURN w.id, sum(2*s - 1) AS score   // Neo4j: (1+cos)/2
ORDER BY score DESC;
```

Fig. 3. Excerpts of `gds.cypher` and of the Cypher form of rule R4.

D. A local extractor under the same schema

To test whether the local model could build the layer itself, we ran the same prompt and schema with Llama-3-8B-Instruct (fp16, Ollama, temperature 0) on 40 sampled chunks. Constrained decoding removed malformed output entirely (0 schema failures in 209 records), but 29% of records failed grounding (58 non-verbatim, 3 unknown identifiers, against 6% for gpt-5.4-mini), and agreement with the gpt-5.4-mini layer on (chunk, technique) pairs was F1 0.14 exactly and 0.23 at the technique-family level, at 12.3 s per chunk. The committed layer therefore stays the gpt-5.4-mini build; the 8B model is used only to answer.

V. Graph Data Science and Reasoning

A. Projection and algorithms

A Cypher script (`gds.cypher`) projects only the knowledge-base layer (5,803 nodes, 6,764 relationships); the report layer is left out so no score carries information from the reports the questions come from. On the undirected projection it runs degree centrality, weakly connected components (WCC), Louvain community detection [10] (single-threaded for reproducible community identifiers) and betweenness centrality [11]; PageRank [12] runs on the stored direction (damping 0.85; it converged in 4 iterations), so a node ranks high when much of the knowledge base points at it. Each result is written back as a node property. All algorithms together run in under one second. Fig. 3 shows the core calls and one reasoning query.

B. Topology

Table IV shows the degree distribution. Tactics are hubs (defense-evasion has 304 techniques). Two thirds of CWEs

TABLE IV
DEGREE BY LABEL ON THE KNOWLEDGE-BASE PROJECTION

Label	Nodes	Mean	Median	Max	Isolated
AttackTechnique	1,076	2.68	2	20	0
Tactic	19	72.3	53	304	0
CWE	1,342	3.35	0	317	891
CAPEC	615	2.41	1	17	131
CVE	2,751	1.19	1	4	0

(891 of 1,342) are isolated: without a CWE hierarchy, a CWE is connected only if a CVE or CAPEC points at it. WCC finds 1,116 components: one giant component of 4,451 nodes (1,066 techniques, 344 CWEs, 459 CAPECs, 2,565 CVEs) and mostly singletons.

Centrality. CWE PageRank tracks how often CVEs are labelled with a weakness: `CWE-79` (37.7), `CWE-89` (21.7), `CWE-74` (13.4), `CWE-200`, `CWE-787`. Technique leaders are `T1195`, `T1027`, `T1036` and `T1218`. CAPEC nodes have only outgoing edges, so their PageRank is flat; betweenness ranks them instead and identifies the bridges between the vulnerability side and the ATT&CK side: `CWE-20`, `CWE-79`, `CWE-200` and `CAPEC-13`, `CAPEC-60`, `CAPEC-76`.

Communities. Louvain finds 1,149 communities with modularity 0.864 over four levels. The largest group CVEs around one weakness family (cross-site scripting, 384 nodes; input validation, 361; SQL injection, 278; out-of-bounds reads, 231) or techniques around tactics (persistence and privilege escalation, 327; defense evasion, 228). As a check of semantic coherence, 79.4% of techniques fall in a community whose dominant tactic is one of their own, although tactics were only one of six relationship types in the projection.

Paths. The CVE → CWE ← CAPEC → technique bridge links the two tasks: 260 CWEs have CVE examples, 336 have CAPEC patterns and 149 reach at least one technique through CAPEC; 189 techniques have a CAPEC. The graph holds 7,866 such paths. A Dijkstra shortest path, for example, connects `CVE-2020-12790` → `CWE-74` → `CAPEC-13` → `T1562.003` in three hops.

C. Rule-based reasoning: snapshot bridges

Beyond R1–R3, three rules run per question as a vector search followed by one-hop aggregation over the graph. With unit-normalized embeddings and similarity $s(q,x)$, a bridge scores a target t by the records that point to it:

$$S_B(t) = \sum_{x \in \mathrm{top}_{n_B}(B,q),\ x \to t} s(q,x), \tag{1}$$

for R4, CAPEC patterns (n = 10, via `EXPLOITS_WEAKNESS`); R5, CVE examples (n = 20, via `HAS_WEAKNESS`); and R6, report behaviors from other reports (n = 30, via `GROUNDS`). Rankings are fused by reciprocal-rank fusion [6], $\mathrm{RRF}(v) = \sum_r 1/(60 + \mathrm{rank}_r(v))$. ATA fuses dense retrieval over all techniques (question and passage) with R6; VCA fuses dense retrieval over CWEs with R4 and R5. Each bridge is also a single Cypher query; run end to end through Neo4j, SGS scores F1 0.452 against 0.466 in memory, a one-question difference caused by near-ties between 32-bit and 64-bit similarities. Table V summarizes the six rules and Table VI what each ranking contributes alone.

TABLE V
SNAPSHOT-DERIVED RULES AND HOW SGS USES THEM

Rule	Inference	Use and development-split evidence
R1 Domain	Enterprise, Mobile or ICS from platforms and ID	shown on cards, never a filter (a filter raised ATA recall@5 0.57 to 0.60 only by assuming the answer space)
R2 Retired ID	parent ID with a sub-technique's title	stored; excluding them is an ablation only
R3 Hierarchy, tactics	ID pattern, kill-chain phases	tactics on cards; tactic-first narrowing lowered recall@5 0.57 to 0.50 (the model names the tactic 50% of the time)
R4 CAPEC bridge	passage ≈ CAPEC → CWE	VCA candidates; CAPEC name on cards
R5 CVE vote	passage ≈ CVE → CWE	VCA candidates; closest CVE on cards
R6 Report vote	passage ≈ behavior → technique	ATA candidates; two examples on cards

TABLE VI
RECALL@5 OF EACH RANKING ALONE (DEVELOPMENT SPLIT)

Ranking	ATA (1,076 techniques)	VCA
Dense, full question	0.57	0.40
Dense, quoted passage	0.47	0.21
R6 report-example vote	0.53	–
R4 CAPEC bridge	0.03	0.35
R5 CVE vote	–	0.26
BM25, passage (dropped)	0.30	0.16
Fused (SGS)	0.63	0.65

D. GDS outputs and graph embeddings as retrieval signals

Candidate recall caps every method: the small model cannot choose an answer it never sees. We therefore tested graph signals as rankers on the development split, without the LLM. The *PageRank prior* adds $\beta\,\tilde{p}_v$, the log PageRank scaled to $[0,1]$ within the target label; the *community vote* adds γ times the share of the question's ten nearest knowledge-base nodes, weighted by similarity, that lie in the candidate's Louvain community. We also tested two graph embeddings: *propagated text embeddings*, a training-free GraphSAGE/APPNP-style smoothing [13], [14]

$$H^{(k+1)} = (1-\alpha)X + \alpha D^{-1}AH^{(k)}, \tag{2}$$

with the question's own report edges removed, and node2vec [15] structural embeddings anchored on the question's nearest nodes. Table VII gives the results.

PageRank acts as a base-rate prior: the median gold CWE sits at the 95.5th PageRank percentile (techniques: 70th), and every gold answer has at least one edge even though 66% of CWEs have none. A leak check found no development passage

TABLE VII
CANDIDATE RECALL ON THE DEVELOPMENT SPLIT (NO LLM)

	ATA		VCA	
Ranking	@1	@5	@1	@5
Text embedding of the question	0.40	0.57	0.12	0.40
SGS candidates (dense + R4–R6)	0.33	0.63	0.16	0.65
+ PageRank prior (RRF)	0.43	0.77	0.35	0.63
+ PageRank and community (RRF)	0.40	0.77	0.33	0.65
Propagated text embeddings	0.40	0.80	0.47	0.70
node2vec + text (best)	–	0.60	–	0.56

duplicating a knowledge-base CVE (median best cosine 0.48, none above 0.9). Graph signals mostly sharpen the top of the list (VCA recall@1 0.16 to 0.35), and propagated embeddings give the best recall@5 on both tasks. Weights were chosen on the same split, so these gains are optimistic, and feeding these candidates to the LLM is future work; the frozen SGS configuration evaluated below does not use them.

VI. LLM INTEGRATION AND GRAPHRAG

A. Snapshot-Guided Selection

SGS divides the work: the graph proposes and explains candidates, and the small model only chooses. For each question it (1) extracts the quoted passage and any identifiers by regular expression; (2) retrieves the top five candidates with the fused rankings of Section V; (3) builds one evidence card per candidate from graph paths only; and (4) asks Llama-3-8B-Instruct to choose. ATA cards hold the title, tactics, platforms, first sentence of detection advice and the two report-layer sentences closest to the passage, never from its own report; VCA cards hold the title, consequences, a related CAPEC pattern and the closest CVE example. A real card:

```
T1071.003 | Mail Protocols | tactics:
command-and-control | platforms: Linux, macOS,
Windows, Network Devices | detection: [...] |
report examples: "...the email-based NightClub
(SMTP/IMAP C2) and its 2020-onward successor
Disco..."
```

The prompt, under the system message "You are a cyber threat intelligence analyst.", is:

```
You are mapping a threat-report passage to {MITRE
ATT&CK techniques | CWE weaknesses}.
Passage: "{passage}"
Candidates:
{cards}
Choose the ONE candidate that best describes
the behavior in the passage. Judge by what each
candidate means, not by shared words. Return JSON
with its id.
```

Decoding is constrained to a JSON schema whose only field is an enum of the five candidate identifiers, at temperature 0, and the reply is re-validated by a Pydantic model of the same enum. An identifier outside the list is therefore impossible. For VCA, the list is shown in its five cyclic rotations and the majority wins (ties go to the better retrieval rank), which cancels position bias. The answer text holds exactly one identifier and its title, because the official scorer counts every identifier it finds; an optional explanation step is scrubbed of all other identifiers.

Tested and dropped. Several alternatives lost on the development split: showing ten candidates instead of five lowered selection accuracy even when the gold was listed (ATA 0.50 vs 0.59, VCA 0.43 vs 0.54); a pairwise tournament in both orders reached at most 0.40 on either task with up to eight calls; a rotation vote for ATA was no better than one call; and narrowing ATT&CK candidates to the model's guessed tactic hurt recall (Table V). A separate fact-checking layer was unnecessary: once candidates are shown, the model's identifier and title contradict the graph in 1 of 12 sampled pairs, against 11 of 21 closed-book.

B. Graph citations and provenance tracking

Every answer carries the graph paths behind the chosen identifier, kept in the trace and the API response rather than the scored text. A *report* citation is a path `ThreatReport` → `ReportChunk` → `ReportBehavior` → technique with the behavior's character span, tier and `GROUNDS` confidence; *capec* and *cve* citations are bridge paths with their similarity to the passage and, for CVEs, NVD's Primary or Secondary tag; *taxonomy* citations are tactic and hierarchy edges. Each citation records whether the model saw it on the card, and carries a Cypher `MATCH` that returns exactly that path. For development question `ata-012` (Androxgh0st abusing SMTP), SGS answers `T1071.003` and cites `BLOG-210` → `BLOG-210#0` → "the email-based NightClub (SMTP/IMAP C2)" → `T1071.003`, characters 195–235 of a different report, confidence 0.76.

C. Interfaces

A service layer turns an `AttributionRequest` into an `AttributionResponse` (answer, explanation, candidates and cards, votes, LLM calls, citations, latency). A FastAPI app exposes it (`POST /attribute`, `GET /graph/{id}` for an answer node's PageRank and Louvain community, `POST /verify` for live path checks, which accepts a citation path rather than raw Cypher and runs a parameterized, schema-checked query). A Streamlit chatbot shows the answer, timings and tabs for citations with a "verify in Neo4j" button, the cited subgraph, the candidates and cards, the answer's graph analytics and every LLM call.

VII. EVALUATION AND DISCUSSION

A. Setup

The 379 attribution questions (ATA 160, VCA 219; one gold identifier each) are split by source report (seed 13) into a development split of 73 questions from 29 reports (30 ATA, 43 VCA) and a test split of 306. All design decisions were made on the development split, and all results below are on it; the test split has not been run and is reserved for future work. Every method uses Llama-3-8B-Instruct at fp16 (`llama3:8b-instruct-fp16`, Ollama 0.35.0, temperature 0) and text-embedding-3-large, and is scored by CTIConnect's official identifier F1, vendored unmodified. A failed call scores

TABLE VIII
F1 ON THE DEVELOPMENT SPLIT (LLAMA-3-8B FP16)

Method	ATA (30)	VCA (43)	Overall
CB, closed-book	0.033	0.132	0.091
VR, vanilla RAG	0.289	0.233	0.256
Cards, one listwise call	0.33	0.35	0.34
+ report examples (R6)	0.43	0.35	0.38
+ VCA rotation vote = **SGS**	**0.433**	**0.488**	**0.466**
SGS, candidates from Neo4j	0.433	0.465	0.452
CTIConnect reported, Llama-3-8B, all 379 questions:			
VR / DtR	0.28 / 0.28	0.22 / 0.40	–

TABLE IX
IDENTIFIER HALLUCINATION, SHARE OF THE 73 ANSWERS

Method	Fabricated ID	No ID	Hedged (>1 ID)
CB, closed-book	10% (ATA 23%)	7%	11%
VR, vanilla RAG	0%	0%	23%
SGS	0%	0%	0%

zero rather than being dropped. Baselines are CTIConnect's closed-book (CB) and vanilla RAG (VR, top-5 knowledge-base records retrieved by the question), with their prompts verbatim. Two pairs of ATA questions are identical but have different gold answers, so the ATA ceiling is 0.988. Significance uses paired bootstrap intervals [16] (10,000 resamples) and McNemar's exact test [17] on exact match.

B. Response accuracy

Table VIII gives F1 with the ablation ladder. SGS reaches 0.466 against 0.256 for vanilla RAG on the same questions. The paired difference is +0.210 (95% CI [+0.082, +0.338]); by task it is +0.256 [+0.093, +0.419] for VCA and +0.144 [−0.067, +0.356] for ATA, where 30 questions do not resolve it. On exact match SGS is right where VR is wrong on 24 questions and the reverse on 5 (McNemar $p = 0.0005$). Scoring answers as (report, predicate, identifier) triples against 69 gold triples gives triple F1 0.511 for SGS, 0.253 for VR and 0.130 for CB. The ladder attributes the gain: graph candidates and cards (+0.08 over VR), report-layer examples for ATA (+0.10 on ATA) and the rotation vote for VCA (+0.14 on VCA). With one question worth 0.03 (ATA) or 0.02 (VCA), single-question differences between configurations are noise.

C. Hallucination

We count, for each answer, whether it names an identifier absent from the snapshot (fabricated), names none, or names several (hedged; the scorer counts all of them). Table IX shows that retrieval alone removes fabricated identifiers but not hedging, and that SGS removes both by construction. Closed-book fabricates in 23% of ATA answers, for example the nonexistent `T1193.001` three times.

D. Faithfulness and provenance

With its explanation step, SGS also scores higher than VR on RAGAS [7] over the 20 evaluation queries (judge gpt-5.4-mini; contexts are exactly what each method showed the model): faithfulness 0.51 vs 0.46, answer relevancy 0.67 vs 0.60 and context recall 0.46 vs 0.39. Faithfulness near 0.5 reflects that the questions' extra asks (affected platforms, business consequences) are answered from the model's own knowledge, which the cards do not cover. For provenance, the 73 SGS answers carry 249 citations (79 report, 66 CAPEC, 58 CVE, 46 taxonomy); every answer has at least one evidence path, and all 249 Cypher queries return exactly one path from the live graph. Correct and wrong answers carry about as many evidence paths (2.71 vs 2.85), so citations make an answer checkable but do not by themselves indicate that it is right.

TABLE X
WHERE SGS ANSWERS GO WRONG (DEVELOPMENT SPLIT)

	ATA (30)	VCA (43)
Correct	13	21
Gold not in the five candidates	11	15
Gold listed, another chosen	6	7
Accuracy when the gold is listed	0.68	0.75

E. Latency and extraction quality

On the local Ollama, an ATA answer takes 4.0 s on average (one call) and a VCA answer 15.1 s (five rotation calls, at most 17.4 s); the LLM accounts for over 99% of the time, while retrieval takes about 5 ms and building citations about 7 ms. Extraction quality is reported in Section IV: precision 0.61 from the stratified audit. Extraction recall was not measured, since the snapshot has no chunk-level labels; as a proxy, 29 of 30 development ATA gold techniques have at least one example from another report.

F. Error analysis

Table X splits the 39 wrong SGS answers by whether the gold identifier reached the model. Two thirds (26) are retrieval misses: the gold was not among the five candidates. When it was listed, the model chose it in 68% of ATA and 75% of VCA questions, and on VCA it was right three times when the gold was ranked fifth, which is the rotation vote at work. Two of the six ATA selection errors chose a sibling or parent of the gold technique. The VCA vote is also a usable confidence signal: unanimous answers (5 of 5 rotations) were correct in 10 of 16 questions, two-vote answers in 1 of 5.

G. Discussion

The results support the project's premise. A small model given the same knowledge as raw retrieved text (VR) improves over closed-book, but it still generates: it hedges, and it misreads identifiers. Moving generation into the graph, so that the model only compares five evidence cards, nearly doubles F1, and the evidence that matters most is relational: report wording from *other* reports for ATA (R6) and CAPEC and CVE examples for VCA (R4, R5). The remaining errors are mostly retrieval misses (the gold is in the top five for 63% of ATA and 65% of VCA questions) and confusions between

sibling sub-techniques, which the GDS and graph-embedding signals of Table VII target.

Limitations. All results come from a 73-question split that also guided design, so they are optimistic and their intervals are wide; the 306-question test split remains to be run once. The audit behind the 0.61 extraction precision is a single first-pass annotation of 75 edges. The graph lacks a CWE hierarchy by design, which leaves two thirds of CWEs isolated. VCA latency is driven by the five-call vote. The scope approved for this course excludes entity-linking and multi-hop tasks, named-entity disambiguation of free-text mentions and an RDF export.

Future work. Run the held-out test split; feed the PageRank and propagated-embedding candidates to the LLM; weight report-layer votes by edge confidence; re-audit the extraction with a second annotator; and test smaller and newer open models.

VIII. Conclusion

Snapshot-Guided Selection shows that a knowledge graph built only from a benchmark's public snapshot can make a small local model a much better CTI attributor when the graph does the retrieving and the explaining and the model only chooses. On the development split it nearly doubles F1 over vanilla RAG, removes identifier hallucination, and returns every answer with provenance-rich graph citations that verify against the live graph. Graph Data Science shows the graph's structure (tactic-aligned communities, bridge nodes between vulnerabilities and techniques, and the cost of a missing CWE hierarchy) and points to the next gains in retrieval.

References

[1] Y. Cheng, Y. Liu, C. Li, D. Song, and P. Gao, "CTIConnect: A benchmark for retrieval-augmented LLMs over heterogeneous cyber threat intelligence," in *Proc. KDD*, 2026, arXiv:2510.11974.

[2] Y. Cheng, C. Li, Q. Cui, L. Wang, Y. Chen, W. Ding, and P. Gao, "CTI-Foundry: An agent-native corpus scaffold for cyber threat intelligence," arXiv:2608.18613, 2026.

[3] A. Boyer, E. Dogdu, R. Choupani, J. S. Watson, D. Sanchez, and A. Ametu, "Toward a unified cybersecurity knowledge graph: Leveraging ontologies and open data sources," in *Recent Advances in Next-Generation Data Science*. Springer, 2024.

[4] P. Lewis *et al.*, "Retrieval-augmented generation for knowledge-intensive NLP tasks," in *Proc. NeurIPS*, 2020.

[5] D. Edge, H. Trinh, N. Cheng, J. Bradley, A. Chao, A. Mody, S. Truitt, and J. Larson, "From local to global: A graph RAG approach to query-focused summarization," arXiv:2404.16130, 2024.

[6] G. V. Cormack, C. L. A. Clarke, and S. Büttcher, "Reciprocal rank fusion outperforms Condorcet and individual rank learning methods," in *Proc. SIGIR*, 2009.

[7] S. Es, J. James, L. Espinosa-Anke, and S. Schockaert, "RAGAS: Automated evaluation of retrieval augmented generation," in *Proc. EACL (System Demonstrations)*, 2024.

[8] B. E. Strom *et al.*, "MITRE ATT&CK: Design and philosophy," The MITRE Corporation, Tech. Rep., 2018.

[9] A. Hogan *et al.*, "Knowledge graphs," *ACM Computing Surveys*, vol. 54, no. 4, 2021.

[10] V. D. Blondel, J.-L. Guillaume, R. Lambiotte, and E. Lefebvre, "Fast unfolding of communities in large networks," *J. Stat. Mech.*, P10008, 2008.

[11] U. Brandes, "A faster algorithm for betweenness centrality," *J. Math. Sociol.*, vol. 25, no. 2, pp. 163–177, 2001.

[12] L. Page, S. Brin, R. Motwani, and T. Winograd, "The PageRank citation ranking: Bringing order to the web," Stanford InfoLab, Tech. Rep., 1999.

[13] W. L. Hamilton, R. Ying, and J. Leskovec, "Inductive representation learning on large graphs," in *Proc. NeurIPS*, 2017.

[14] J. Gasteiger, A. Bojchevski, and S. Günnemann, "Predict then propagate: Graph neural networks meet personalized PageRank," in *Proc. ICLR*, 2019.

[15] A. Grover and J. Leskovec, "node2vec: Scalable feature learning for networks," in *Proc. KDD*, 2016.

[16] B. Efron and R. J. Tibshirani, *An Introduction to the Bootstrap*. Chapman & Hall, 1993.

[17] Q. McNemar, "Note on the sampling error of the difference between correlated proportions or percentages," *Psychometrika*, vol. 12, no. 2, pp. 153–157, 1947.